

The CIA Triad (1.2)

Date: / /

Combination of Principles

- Fundamentals of security → CIA/AIC Triad.

Confidentiality -

- Prevent unauthorized information disclosure.

- Encryption
- Access control
- Two-factor authentication.

Integrity -

- Data is stored and transferred as intended.

(any modification to data would be identifiable)

* Hashing

* Digital signature (additional level).

* certificates

* Non-repudiation.

Availability -

- Information is accessible to authorised users. (always at your fingertips)

* Redundancy

↳ services that will always be available.

* Fault tolerance

↳ system will continue to run even when failure occurs.

* Patching.

↳ stability

↳ close security holes.

Non-repudiation

Basic Idea :- You can't Deny what you've said.

(There is No Taking Back)

Proof of Integrity

The data remains accurate and consistent.

⇒ In Cryptography, we use a hash

→ data in form of short string

(if the data changes, the hash changes)

eg:- Hashing a Encyclopedia

— X — X — X —

Proof of Origin.

— prove the message was not changed

— prove the source of message

(Authentication)

— Make sure the signature isn't fake.

(Non-repudiation)

— Sign with private key.

— Verify with the public key.

(any changes → invalidate the signature)

AAA Framework

Date: / /

Identification

- This is who you claim to be
(username)

Authentication

- Prove that you are who you say you are
(password and other auth. factors)

Authorization

- Based on your identification and authentication, what access do you have.
(access to what you supposed to)

Accounting

- Resources used :
 - login time
 - data sent & received.
 - logout time.

Certificate Authentication

Date: / /

- An Organization has a Trusted Certificate Authority (CA)
(most org. maintain their own CAs)
- Org. creates a certificate for a device.
(Digitally signs the certificate with org. CA's)
- The certificate is now included on a device as authentication factor.
(CA's signature is used to validate the certificate).

Authorization model →

- Defines what a user is allowed to access and do.
(Rules that decides user permission).

Goal :- Streamlined administration for large no. of people.

Gap Analysis

Date: / /

- Where you are compared to where you want to be.
(The "gap" between Two).

Choosing the Framework

(Determine the end goal)

- NIST special Publication 800-171 Rev. 2,
Protecting Controlled unclassified -
Information in nonfederal systems
and organisation.
- ISO/IEC 27001,
Information security management
systems.
- create own baseline
Based on your specific need as an
organisation.

Evaluate people and processes

- Formal experience
- current training
- Knowledge of security policies and procedures.

Examine the current processes.

- Research existing IT systems.
- Evaluate existing security policies.

Compare and Contrast

- Evaluate existing systems
- Identify weaknesses

Ultimately create a Detailed Analysis

- Examine broad security categories
- Break those into smaller segments.

Report Analysis

- final comparison
- Path needed to reach goal.
- time, money, lots of change.

Zero Trust

Date: / /

Everything must be verified —

- Nothing is inherently trusted
- MFA, encryption, system permissions, additional firewalls, monitoring and analytics, etc.

Planes of operation.

* Data plane

- process the frames, packets and network data.
- processing, forwarding, trunking — encrypting, NAT.

* Control plane

- manages the action of data plane.
- Defines policies and rules.
- Determines how packets should be forwarded.
- Routing table, session table, NAT tables.

Controlling Trust

- Adaptive Identity.

- Consider the source and requested resources.
- Relationship to Org., physical location, type of connection, IP address.

- Threat scope reduction.

- Decrease the number of possible entries.

- Policy driven access control.

- Combine the adaptive identity with a predefined set of rules.

Security zones.

- Trusted, untrusted

- Internal network, external network.
- VPN 1, VPN 5, VPN 11
- Marketing, IT, Accounting, HR.

Policy enforcement point (PEP)

- subjects and systems

(end users, applications, non-human act)

- policy enforcement point (PEP)

(the gatekeeper).

Applying Trust in the planes.

Policy Engine Decision Point (PDP)

⇒ Policy Engine

- evaluates each access decision based on policy and other information sources.

- Grant, deny, revoke.

⇒ Policy Administrator.

- communicates with the Policy Enforcement point (PEP)

- Generates access tokens or credentials.

- Tells the (PEP) to allow or disallow the access.

Physical Security.

Date: / /

Barricades / Bollards.

- Allow people, prevent cars & Trucks.
- (used to channel people through access point)

Access control vestibules.

- one at a time, controlled groups.
- (managed control through an area).

Video surveillance.

- CCTV (closed circuit television)
- (can replace physical guards)

Guards and access badges

- validate identification
- two person for integrity / control
- electronically logged access badge.

Sensors.

- Infrared :- detects radiation
- Pressure :- change in force
- Microwave :- large areas
- Ultrasonic :- sound waves.

Deception and Disruption

Date: / /

Honeypots

- attract bad guys by creating a fake virtual world to explore.

Honeynets

- larger deception network with one or more honeypots.

Honeyfiles.

- create files with fake information
(Bait like : password.txt)

Honeytokens

- Add traceable data to the honeypot.
- API credentials (does not provide access)
- Notifications are sent when used.
- fake email address.
- add to contact list.
- monitor the internet to see who posts it.